

Cirque Corporation

Key Management Procedure

Document ID: IS-CIRQ-PR-010-G

Category: IT Security Related

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to establish the systematic process for managing cryptographic keys throughout their entire lifecycle, from generation to destruction. This procedure ensures the secure and effective use of cryptography in accordance with IS-CIRQ-P-009-G: Cryptography Policy and ISO/IEC 27001:2022 Annex A.8.24, safeguarding the confidentiality, integrity, and authenticity of Cirque's information.

****2. Scope****

2. Scope

This procedure applies to all cryptographic keys used by Cirque to protect its information assets, including but not limited to:

- Keys for Full Disk Encryption (FDE) (e.g., managed by Intune).
- Keys for data encryption at rest (e.g., database encryption, file server encryption).

- Keys for data in transit encryption (e.g., VPNs, TLS certificates for websites, secure email gateways).

- Digital signature keys.

- Keys used for Multi-Factor Authentication (MFA).

****3. Responsibilities****

3. Responsibilities

- ****IT Manager:**** Overall owner of this procedure. Responsible for ensuring the secure implementation and operation of key management practices, including key generation, storage, distribution, and destruction.

- ****System Administrators / IT Personnel:**** Responsible for executing key management tasks as directed by the IT Manager and in accordance with this procedure.

- ****Cloud Service Providers:**** Responsible for their underlying key management practices where Cirque utilizes their native encryption features (e.g., Microsoft 365, Azure). Cirque remains responsible for policy enforcement and configuration of customer-managed keys.

****4. Procedure****

4. Procedure

****4.1. Key Generation**** a. Cryptographic keys shall be generated using approved, cryptographically strong algorithms and robust random number generators. b. Keys for high-assurance applications (e.g., root Certificate Authority keys, master encryption keys) shall be generated in secure, controlled environments, ideally using Hardware Security Modules (HSMs) or equivalent secure cryptographic devices if available.

c. Key lengths shall adhere to current industry best practices and IS-CIRQ-P-009-G: Cryptography Policy.

****4.2. Key Storage**** a. ****Secure Storage:**** Cryptographic keys shall be stored securely, segregated from the encrypted data, and protected against unauthorized access, disclosure, or modification. b.

****Designated Locations:**** * ****Production Keys:**** Stored in dedicated key management systems, secure key vaults (e.g., Azure Key Vault), or HSMS. * ****System Keys:**** Passwords for service accounts or system-level keys may be stored in an approved, encrypted password manager or vault accessible only to authorized IT personnel. * ****Endpoint FDE Keys:**** Recovery keys for Full Disk Encryption (e.g., BitLocker recovery keys) shall be securely stored and managed (e.g., within Intune or Active Directory). c. ****Access Control:**** Access to key storage locations shall be strictly controlled on a need-to-know basis, with multi-factor authentication for privileged access. d. ****Encryption of Stored Keys:**** Keys, especially those stored outside of HSMS, shall themselves be encrypted where technically feasible.

****4.3. Key Distribution**** a. ****Secure Channels:**** Keys shall be distributed only through secure, authenticated, and encrypted channels. b. ****No Unsecured Transmission:**** Keys must never be transmitted via unencrypted email or other unsecured communication methods. c. ****Automated Distribution:**** For endpoints, FDE keys are managed and distributed via ****Intune****. d. ****Manual Distribution:**** For manual key exchange (e.g., for VPN pre-shared keys), secure out-of-band methods shall be used (e.g., encrypted communication, physical delivery).

****4.4. Key Usage**** a. ****Intended Purpose:**** Keys shall be used only for their intended cryptographic purpose (e.g., an encryption key for encryption, a signing key for digital signatures). b. ****Least Privilege:**** Access to use keys shall be granted based on the principle

of least privilege. c. **Logging:** All uses of critical cryptographic keys shall be logged where possible, for auditing purposes.

4.5. Key Backup and Recovery a. **Regular Backups:** All critical cryptographic keys shall be regularly backed up in a secure, encrypted format to ensure availability in case of loss or corruption. b. **Secure Storage for Backups:** Key backups shall be stored in a separate, secure location, distinct from the primary key storage. c. **Recovery Procedures:** Documented procedures for secure key recovery shall be established and regularly tested to ensure integrity and functionality.

4.6. Key Archiving and Rotation a. **Key Archiving:** Keys that are no longer actively used but are still required for decryption of archived data (e.g., for legal retention purposes) shall be securely archived. b. **Key Rotation:** Critical cryptographic keys (e.g., server certificates, VPN keys, database encryption keys) shall be periodically rotated as defined by risk assessments and industry best practices. The rotation frequency will be determined by the IT Manager.

4.7. Key Destruction a. **Secure Destruction:** Keys shall be securely destroyed when they are no longer required and their retention period has expired. b. **Methods:** Destruction methods shall ensure that the keys are irretrievable (e.g., cryptographic erasure for software keys, physical destruction for hardware tokens/HSMs if necessary). c. **Documentation:** The destruction of critical keys shall be documented.

5. Review and Update

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's cryptographic controls, IT environment, threat landscape, or legal/regulatory requirements.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-009-G: Cryptography Policy
- IS-CIRQ-P-007-G: Asset Management Policy
- IS-CIRQ-PR-007-G: Asset Classification and Handling Procedure
- IS-CIRQ-P-008-G: Access Control Policy
- IS-CIRQ-PR-008-G: Access Control Procedure
- IS-CIRQ-PR-009-G: Privileged Access Management Procedure